

Every PrescribeRx API request must carry a Sanctum bearer token. The token's **type** determines which endpoints it can hit, the data scope (single tenant vs. hierarchy), and which payload fields are honoured. This page lists the four production token types, how to provision each, and what they're allowed to do.

How to authenticate: All tokens are passed as `Authorization: Bearer {token}`. Tokens are generated by an authenticated user (or admin) and inherit that user's `UserType`. Token abilities are computed from `TokenAbility::forUserType()` at issue time — see "Updating abilities" at the bottom for what happens when the mapping changes.



Sales Organization Token

`UserType::2`

Who uses it	A sales organization integrating PrescribeRx into their own product (white-label, partner site, or back-office portal).
How to provision	Provisioned by the sales-org owner from <code>/sales-organization/api-tokens</code> , OR by an admin attaching a token to any user with <code>UserType::SALESORGANIZATION</code> .
Data scope	Tenant-scoped to the org and all its hierarchical descendants (child orgs + clients + their patients/encounters/orders). Cannot read other orgs.
Common use cases	• Submitting telehealth intakes from a partner-branded site • Querying products + packages available to the org • Reading orders + encounters across the org hierarchy • Managing webhook subscriptions for org-wide events
▶ Token abilities (21)	
▶ Example: cURL request	



Client Token (CLIENT / CLIENTMANAGER / CLIENTPROVIDER)

`UserType::6`

Who uses it	A client (clinic, pharmacy partner, individual practice) using PrescribeRx APIs from their own EHR / portal / PMS.
How to provision	Provisioned by the client owner from <code>/client/settings/api-tokens</code> , OR by a sales-org admin on behalf of the client.
Data scope	Tenant-scoped to a single client. Sees only their patients, encounters, orders, prescriptions. CLIENTPROVIDER variant adds

prescription:create + prescription:sign for client-side providers signing Rx.

Common use cases

- Submitting a telehealth intake on behalf of a patient
- Reading a patient chart + visit history
- Creating client-to-patient and bulk-to-client orders
- Subscribing to webhooks for client-scoped events

► Token abilities (19)

► Example: cURL request

User Token (PATIENT / PROVIDER / etc.)

UserType::1

Who uses it

An individual user (patient, provider, sales-org employee) authenticating from a mobile app or first-party SPA.

How to provision

Issued via /api/v1/auth/login (mobile) or via the user's portal "Generate API Token" button. Scoped to that user's UserType.

Data scope

User-scoped. Sees only their own data (patient sees own chart, provider sees their own assigned encounters). Cannot impersonate other users.

Common use cases

- Mobile app login flows
- A provider reviewing their own assigned encounters
- A patient pulling their own chart from their own integration

► Token abilities (9)

► Example: cURL request

Embed Form Token

UserType::3

Who uses it

A public embed form (web widget on a partner site) that submits intakes anonymously without authenticating an end-user first.

How to provision

Generated when an embed code is created from /admin/embeds. Tied to a specific encounter type + embed instance + sales-org. Lower-privilege than a sales-org token.

Data scope

Locked to the single embed_code. Can only submit intakes that match that embed's encounter type and any product allow-list. Cannot read existing data.

Common use cases

- A weight-loss page on a partner site that drops a single embed widget
- Lead-gen funnels that collect intake then redirect to PRX-hosted checkout
- Quick-deploy partner integrations that need zero auth-server work

- ▶ Token abilities (1)
- ▶ Example: cURL request

Capability matrix

Action	sales-org	client	user	embed
Submit telehealth intake	✓	✓	✓ (own)	✓ (single embed)
Query products / packages	✓ scoped	✓ scoped	✓ public catalog	✓ embed catalog
Create orders	✓	✓	✗	✗
Read encounters	✓ org tree	✓ client only	✓ assigned	✗
Sign prescriptions	✗	CLIENTPROVIDER only	PROVIDER only	✗
Manage webhooks	✓	✓	✗	✗
Read other tenants	✗	✗	✗	✗
Admin operations	✗	✗	✗	✗

Picking the right token

Scenario	Use this token
Building a partner-branded telehealth site that lists products and submits intakes	sales-org
EHR / clinic PMS submitting intakes for their own patients	cclient (CLIENTMANAGER variant for clinic admin)
Provider EHR signing prescriptions back into PRX	cclient (CLIENTPROVIDER variant)
Mobile app a patient logs into	user (PATIENT)
Drop a single intake widget on a marketing page	embed

Scenario	Use this token
Internal admin tooling / cron / sysadmin	API (full ability — request from sysadmin)

Updating abilities

Tokens are frozen at issue time. If `TokenAbility::forUserType()` changes (new ability added, retired ability removed), *existing* tokens keep their old ability list until they're rotated or until an admin runs `php artisan api:sync-token-abilities`. This is by design (auditability) but means you should always run the sync command after any change to `TokenAbility`.

Authentication errors

Status	Meaning	What to check
401	Missing or invalid bearer token	Header format <code>Authorization: Bearer ...</code> ; token hasn't been revoked
403	Token is valid but lacks the ability for this endpoint	Confirm token type matches the action — see the matrix above
422	Payload validation failed	Per-field errors in the response body. Common causes: wrong format (UUID vs. prod-XXX), missing required dependent fields
429	Rate-limited	Default 60 req/min per token. Back off + retry with <code>Retry-After</code>